

5.1. УПРАВЛЕНИЕ ДОСТУПОМ К ФАЙЛАМ НА NTFS

Цель работы.

Приобретение практических навыков настройки разрешений на доступ к файлам в операционных системах семейства Windows.

Используемые программные средства.

Компьютер или виртуальная машина с установленной ОС Windows 7 или Windows Server 2008. Для выполнения работы необходимы права администратора.

Теоретические сведения.

Операционные системы семейства Windows NT, в которое входят и Windows 7 и 8, обладают достаточно развитыми встроенными механизмами защиты информации. При соответствующей настройке они могут быть эффективно использованы для достижения различных целей безопасности.

Задачи аутентификации пользователей и разграничения доступа к данным взаимосвязаны: эффективного разграничения доступа не может быть без надежной аутентификации. ОС Windows позволяет создавать учетные записи пользователей и группы в локальной базе безопасности, а если компьютер включен в домен, то появляется возможность использовать и доменные учетные записи и группы, которые хранятся в базе Active Directory.

Допустим, компьютер с именем COMP1 включен в домен KAFEDRA. Тогда полное имя учетной записи User, если она является локальной, будет COMP1\User, если доменной — KAFEDRA\User. Начиная с Windows 2000, стал поддерживаться и формат, разделяющий имя пользователя и полное имя домена символом «@». Пусть полное имя домена будет KAFEDRA.mydomain.ru, тогда имя пользователя может быть записано как User@KAFEDRA.mydomain.ru. В ОС Windows имена пользователей и доменов не чувствительны к регистру: имена учетной записи user, User и USER будут равнозначны. Значение пароля чувствительно к регистру.

Пользователи, группы пользователей и компьютеры в домене Windows имеют уникальные идентификаторы безопасности — SID (Security ID). SID имеет уникальное значение в пределах домена и

формируется во время создания пользователя или группы, либо когда компьютер регистрируется в домене. SID сохранится и в том случае, если учетную запись переименовать. Вместе с ним сохраняются и все назначенные разрешения (см. далее). А вот удаление учетной записи и создание новой с тем же именем приведет к изменению SID.

Когда пользователь при входе в систему вводит имя и пароль, ОС выполняет проверку правильности пароля и, если она проходит, создает маркер доступа для пользователя. Маркер включает в себя SID пользователя и все SID'ы групп, в которые данный пользователь входит.

Для объектов, подлежащих защите, таких как файлы и папки, создается дескриптор безопасности. С ним связывается список управления доступом (*англ.* Access Control List — ACL), который содержит информацию о том, каким субъектам даны те или иные права на доступ к данному объекту. Чтобы определить, можно ли предоставить запрашиваемый субъектом тип доступа к объекту, ОС сравнивает SID в маркере доступа субъекта с идентификаторами, содержащимися в ACL.

Для каждого из предусмотренных типов доступа к файлу или папке (чтение, запись и т. д.) пользователю или группе может быть установлено «разрешить» (*англ.* allow), «запретить» (*англ.* deny) или разрешение может быть не установлено. Разрешения суммируются. Например, если у пользователя есть право на чтение, а у группы, куда он входит — на запись, то действующее (или эффективное) разрешение будет включать чтение и запись. Явное запрещение (deny) более приоритетно, чем аналогичное разрешение: например, если у пользователя есть разрешение на операцию, а одной из групп, в которые он входит, эта операция явно запрещена, пользователю эту операцию выполнить будет нельзя. Выполнить действие можно только в том случае, если оно разрешено, то есть отсутствие разрешения в итоговом («эффективном») наборе разрешений пользователя приведет к тому, что он не сможет выполнить соответствующее действие.

Если говорить о файлах и папках, то механизмы защиты на уровне файловой системы поддерживаются только на дисках с файловой системой NTFS. Файловая система FAT (и ее разновидность — FAT32)

не предполагает наличия атрибутов безопасности файла или связанного с файлом ACL. Соответственно, нельзя установить разрешения на файл или папку, находящуюся на диске с FAT.

План лабораторной работы.

Лабораторная работа выполняется под учетной записью, обладающей правами локального администратора на компьютерах в учебном классе. Упражнения выполняются на диске с файловой системой NTFS.

1. В указанном преподавателем каталоге («папке») на локальном диске или диске виртуальной машины создайте новый каталог для выполнения данной лабораторной работы. Там создайте текстовый файл с произвольным содержанием. Просмотрите его разрешения на вкладке «Безопасность» (*англ.* Security) в свойствах файла (щелчок правой клавишей мыши на файле, в выпадающем меню — «Свойства», *англ.* Properties). Вы увидите картинку, аналогичную представленной на рис. 5.1.

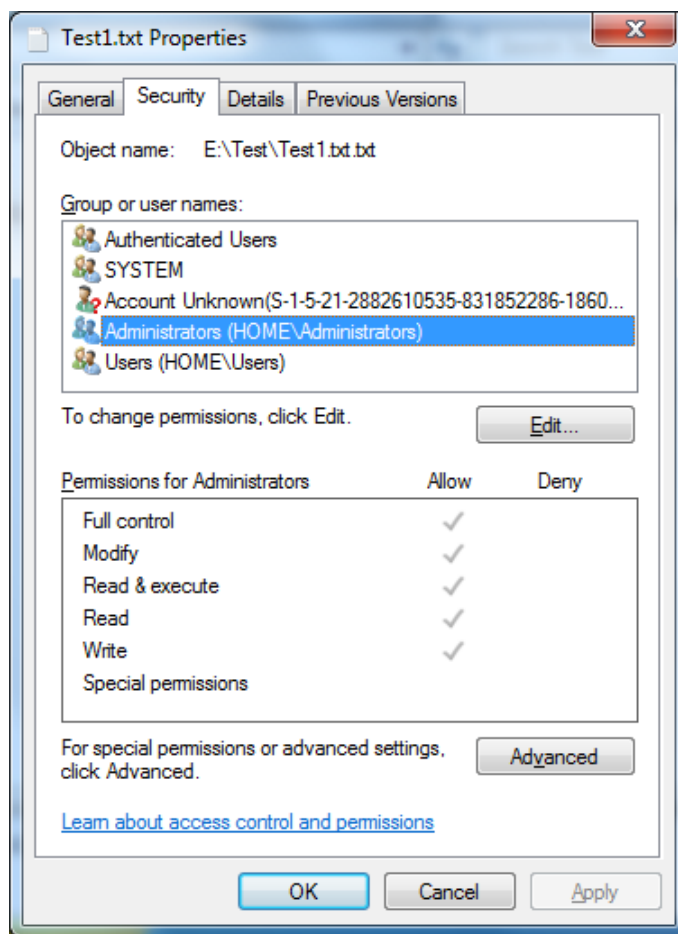


Рис. 5.1. Закладка «Безопасность» в свойствах файла

Обратите внимание, что сначала в списке могут появляться номера, потом они заменяются именами пользователей и групп. Эти номера и есть идентификаторы SID, которые затем, если это возможно, разрешаются в имена. На рис. 5.1 в ACL находится идентификатор удаленной учетной записи, который не может быть разрешен в имя пользователя (*англ.* Account Unknown — неизвестная учетная запись).

Проанализируйте текущие разрешения на созданный вами файл, имеющиеся у различных групп и пользователей. Эти разрешения унаследованы вашим файлом от объекта более высокого уровня, то есть от каталога, в котором он находится. Убедитесь в этом.

Для редактирования ACL нажмите кнопку Edit. Попробуйте выполнить следующие действия:

- добавить в ACL новую учетную запись, дав ей разрешения на изменение файла (*англ.* Modify);
- убрать группу Users из списка доступа на свой файл.

В связи с тем, что используется наследуемый ACL, вторую часть задания выполнить сразу не удастся: сначала нужно создать для объекта собственный ACL. Для этого нажмите кнопку Advanced (рис. 5.1) и в появившемся окне Advanced Security Settings (Дополнительные параметры безопасности) — кнопку Change Permissions (Изменить разрешения). Отказаться от использования наследуемых разрешений можно, убрав отметку Include inheritable permissions from this object's parent (переносить наследуемые от родительского объекта разрешения на этот объект), см. рис. 5.2. При этом будет предложено добавить в собственный ACL объекта разрешения из родительского списка (*англ.* Add) или полностью убрать их (*англ.* Remove). Лучше выбрать первый вариант, а потом уже отредактировать список так, как нужно.

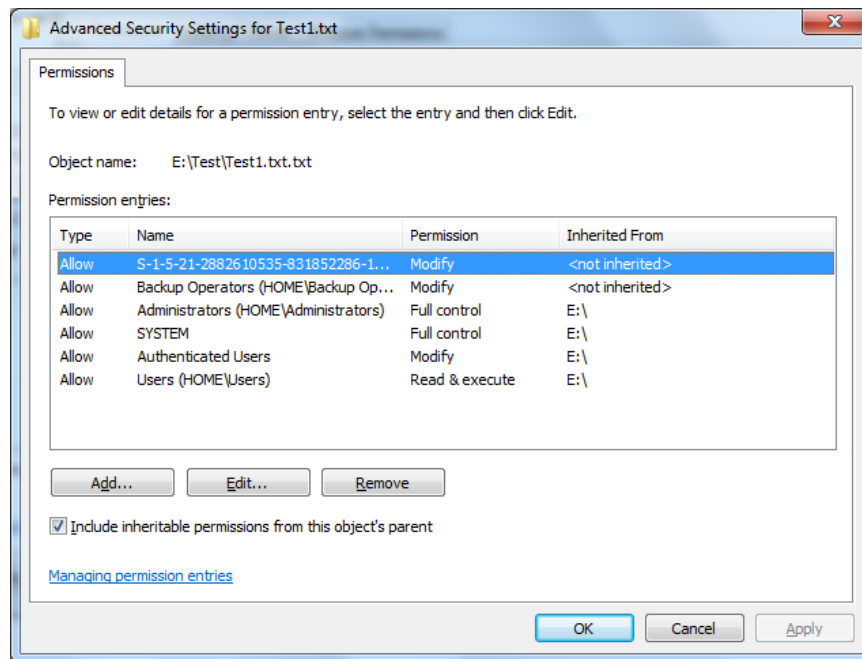


Рис. 5.2. Окно редактирования разрешений

Убрав группу Users (Пользователи) из ACL вашего файла, попробуйте открыть его от имени другой учетной записи, не имеющей явных разрешений и не входящей ни в одну из оставшихся в ACL групп (при необходимости создайте такую учетную запись). Если все сделано правильно, зайдя под подобной учетной записью Вы не получите доступа к файлу.

По умолчанию, локальная группа Users (Пользователи) включает всех локальных и доменных пользователей (если компьютер входит в домен Windows). Ознакомьтесь по справке или указанной ниже статье TechNet с другими стандартными локальными группами.

<http://technet.microsoft.com/ru-ru/library/cc771990.aspx>.

2. По справке или статье <http://technet.microsoft.com/ru-ru/library/cc732880.aspx> ознакомьтесь с разрешениями, которые можно давать на папку или файл в Windows. Подготовьте ответы на приведенные ниже вопросы.

Как можно просмотреть набор элементарных разрешений (из которых составлено, например, разрешение «изменить»), имеющихся у пользователя на файл или папку?

Чем составное разрешение «Изменить» (Modify) отличается от разрешения «Полный доступ» (Full Control)?

Дает ли разрешение на запись в папку право просматривать ее содержимое?

3. Эффективные или действующие разрешения (Effective Permissions) — это итоговые разрешения, складывающиеся из разрешений, данных пользователю и группам, которые и определяют, можно или нельзя данному субъекту получить доступ к данному объекту. Для выбранной учетной записи их можно узнать на вкладке Effective Permissions окна Advanced Security Settings, которое мы уже использовали при выполнении задания 1. Посмотрите действующие разрешения на ваш файл для одной из существующих учетных записей.

Чтобы лучше разобраться правилами назначения разрешений, выполните приведенные ниже задания.

При необходимости создайте локальную группу (назовем ее Students) и включенную в нее учетную запись (Student). Можно воспользоваться уже существующей записью. Группе Students дайте разрешение на чтение созданного вами файла. Проверьте, чтобы пользователь Student отсутствовал в перечне разрешений на файл. Зайдите под этой учетной записью. Может ли данный пользователь прочитать файл?

Повторите эксперимент, дополнительно указав на вкладке «Безопасность», что пользователю Student запрещено чтение файла. Сможет ли пользователь прочитать файл или нет? Ведь, с одной стороны, он в группе, которой разрешено чтение, с другой стороны — ему самому чтение запрещено.

4. Посмотрите разрешения на папку Program Files. Опишите в отчете, каким группам какие разрешения даются на эту папку, куда по умолчанию устанавливаются программы.

5. У объектов файловой системы, таких как файлы, папки и тома, есть владельцы. По умолчанию владельцем объекта становится его создатель. Владелец всегда может изменять разрешения для объекта, даже при отсутствии доступа к нему.

Более подробную информацию по этому поводу можно получить из справки или приведенной ниже статьи TechNet.

<http://technet.microsoft.com/ru-ru/library/cc732983.aspx>.

Ознакомьтесь с этими материалами. Подготовьте ответы на вопросы.

Кто может стать новым владельцем объекта (какие разрешения для этого нужны)?

Как сменить владельца объекта?

Предложите и выполните эксперимент, иллюстрирующий возможности владельца файла, отличающие его от других пользователей.

6. Управлять разрешениями на файлы и папки можно не только из графического интерфейса Windows, но и из командной строки. Для этого рекомендуется использовать утилиту `icacls.exe` (также для совместимости поддерживается утилита `cacls.exe`). С возможностями этой утилиты можно ознакомиться по справке или из статьи TechNet.

<http://technet.microsoft.com/ru-ru/library/cc753525.aspx>.

С помощью утилиты выполните перечисленные ниже действия.

- сохраните текущий ACL выбранного вами файла в текстовый файл;
- предоставьте пользователю Student разрешение на изменение данного файла (`modify`);
- проверьте работу сделанных настроек;
- восстановите исходный ACL из копии, сделанной в начале выполнения задания.

7. При копировании и перемещении файлов на NTFS надо учитывать следующее:

- ACL файла или папки (и соответственно, все разрешения) сохраняется при перемещении объекта в пределах одного тома NTFS;
- при прочих операциях (перемещение между томами или копирование в любых вариантах) ACL заменяется на унаследованный от нового родительского контейнера.

Предложите и реализуйте эксперимент, позволяющий проверить выполнение этих правил.